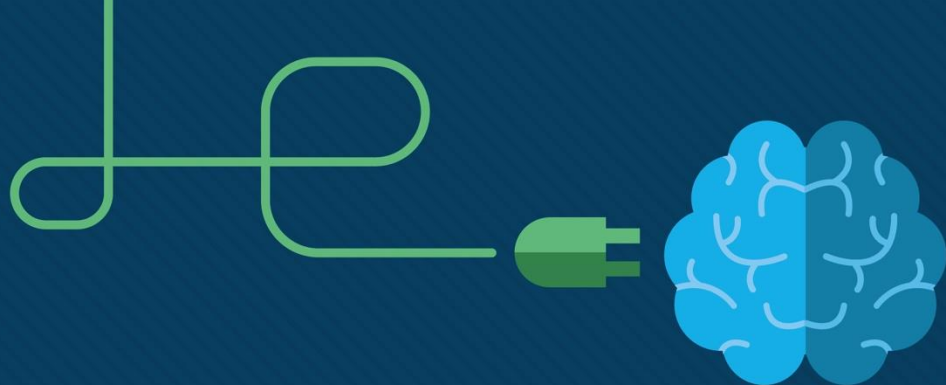




Layer 2 Security Considerations



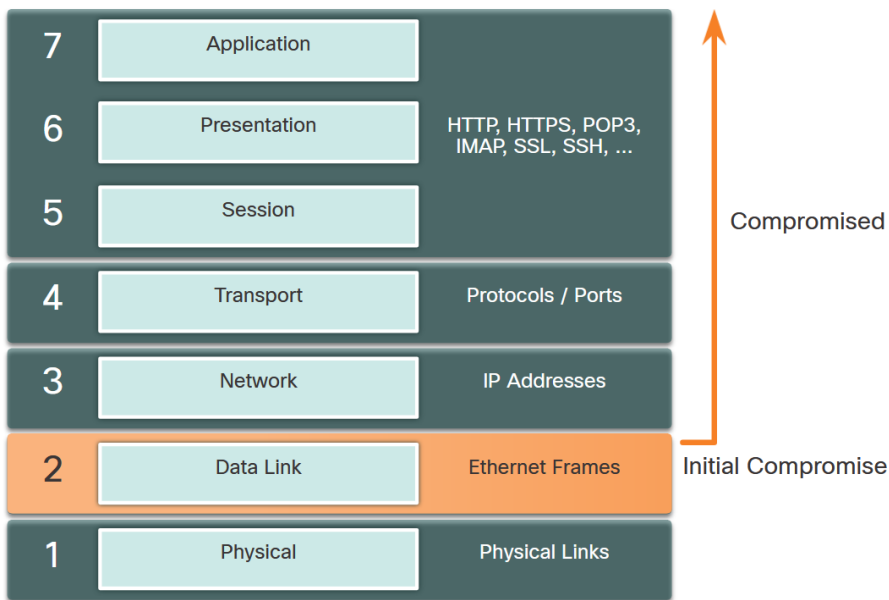
Layer 2 Security Threats

Layer 2 Security Threats

Describe Layer 2 Vulnerabilities

The OSI reference model is divided into seven layers which work independently of each other. Each layer performs a specific function and has core elements that can be exploited.

Network administrators routinely implement security solutions to protect the elements in Layer 3 up through Layer 7 using VPNs, firewalls, and IPS devices. However, as shown in the figure, if Layer 2 is compromised, then all layers above it are also affected.



Layer 2 Security Threats

Switch Attack Categories

Layer 2 is considered to be the weakest link in the network system. Attacks against the Layer 2 LAN infrastructure are highlighted in the table.

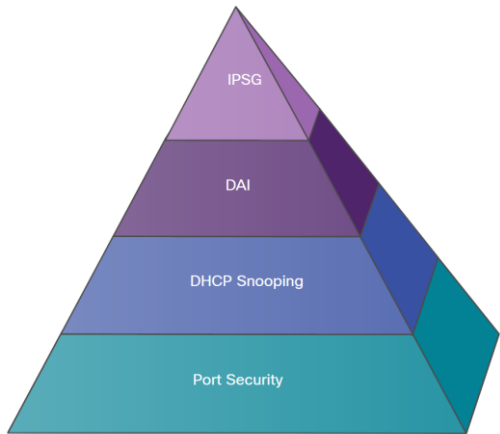
Type	Description
MAC Table Attacks	Includes MAC table overflow (also called MAC Address Flooding) Attacks.
VLAN Attacks	Includes VLAN hopping and VLAN double-tagging attacks. It also includes attacks between devices on a common VLAN.
DHCP Attacks	Includes DHCP starvation and DHCP spoofing attacks.
ARP Attacks	Includes ARP spoofing and ARP poisoning attacks.
Address Spoofing Attacks	Includes MAC Address and IP address spoofing attacks.
STP Attacks	Includes Spanning Tree Protocol manipulation attacks.

Switch Attack Categories (Cont.)

The figure provides an overview of Cisco solutions that help mitigate Layer 2 attacks.

The following strategies are recommended:

- Always use secure variants of these protocols such as SSH, SCP, and SSL.
- Consider using out-of-band (OOB) management.
- Use a dedicated management VLAN where nothing but management traffic resides.
- Use ACLs to filter unwanted access.



Topic Title	Topic Objective
Port Security	Port security prevents many types of attacks including MAC table overflow attacks and DHCP starvation attacks.
DHCP Snooping	DHCP Snooping prevents DHCP starvation and DHCP spoofing attacks by rogue DHCP servers.
Dynamic ARP Inspection (DAI)	DAI prevents ARP spoofing and ARP poisoning attacks.
IP Source Guard (IPSG)	IP Source Guard prevents MAC and IP address spoofing attacks.

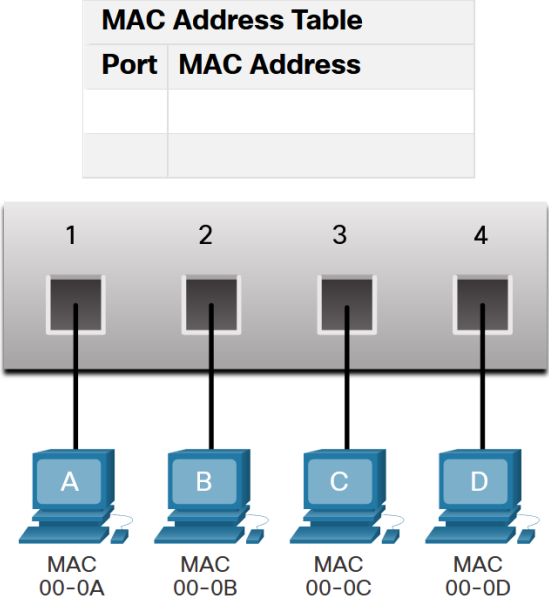
MAC Table Attacks

MAC Table Attacks

Switch Fundamentals

A Layer 2 Ethernet switch uses Layer 2 MAC addresses to make forwarding decisions. It is completely unaware of the data (protocol) being carried in the data portion of the frame, such as an IPv4 packet, an ARP message, or an IPv6 ND packet. The switch makes its forwarding decisions based solely on the Layer 2 Ethernet MAC addresses.

The table shows the MAC Address Table which has not yet learned the MAC addresses for the four attached PCs.



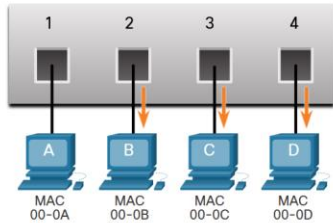
Switch Learning and Forwarding

The switch dynamically builds the MAC address table by examining the source MAC address of the frames that are received on a port. The switch forwards frames by searching for a match between the destination MAC address in the frame and an entry in the MAC address table.

Every frame that enters a switch is checked for new information to learn. The switch does this by examining the source MAC address of the frame and the port number where the frame entered the switch.

If the source MAC address does not exist, it is added to the table along with the incoming port number. If the source MAC address does exist, the switch updates the refresh timer for that entry in the table. By default, most Ethernet switches keep an entry in the table for 5 minutes.

MAC Address Table	
Port	MAC Address
1	00-0A

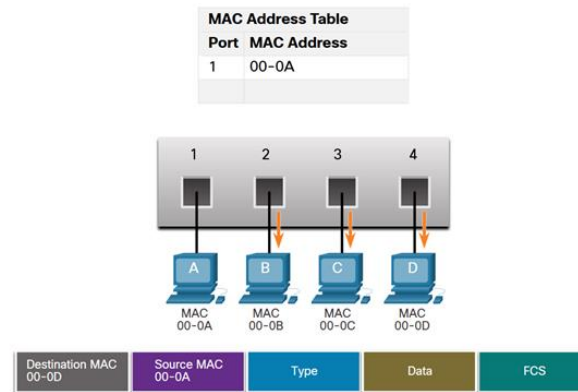


Destination MAC	Source MAC	Type	Data	FCS
00-0D	00-0A			

1. The destination MAC address is not in the table.
2. The switch forwards the frame out all other ports.

Switch Learning and Forwarding (Cont.)

If the destination MAC address is a unicast address, the switch will look for a match between the destination MAC address of the frame and an entry in its MAC address table. If the destination MAC address is in the table, it will forward the frame out the specified port. If the destination MAC address is not in the table, the switch will forward the frame out all ports except the incoming port. This is called an unknown unicast.



1. The destination MAC address is not in the table.
2. The switch forwards the frame out all other ports.

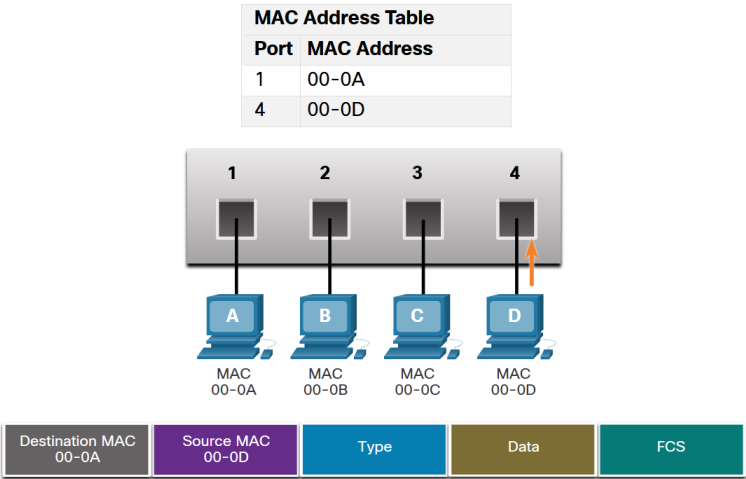
As shown in the figure, the switch does not have the destination MAC address in its table for PC-D, so it sends the frame out all ports except port 1.

MAC Table Attacks

Filtering Frames

As a switch receives frames from different devices, it populates its MAC address table by examining the source MAC address of every frame. When the MAC address table of the switch contains the destination MAC address, it filters the frame and forwards out a single port.

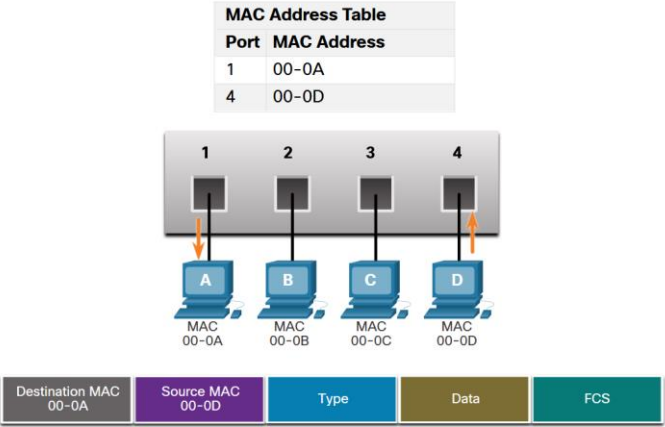
In the figure, PC-D is replying back to PC-A. The switch sees the MAC address of PC-D in the incoming frame on port 4. The switch then puts the MAC address of PC-D into the MAC Address Table associated with port 4.



MAC Table Attacks

Filtering Frames (Cont.)

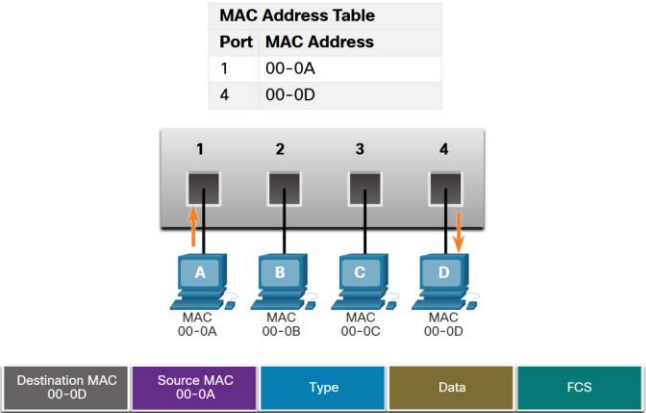
Next, because the switch has destination MAC address for PC-A in the MAC Address Table, it will send the frame only out port 1, as shown in the figure.



- 1. The switch has a MAC address entry for the destination.
- 2. The switch filters the frame, sending it only out port 1.



PC-A sends another frame to PC-D as shown in the figure. The MAC address table already contains the MAC address for PC-A; therefore, the five-minute refresh timer for that entry is reset. Next, because the switch table contains the destination MAC address for PC-D, it sends the frame only out port 4.



- 1. The switch receives another frame from PC-A and refreshes the timer for the MAC address entry for port 1.
- 2. The switch has a recent entry for the destination MAC address and filters the frame, forwarding it only out port 4.

Table d'auto-apprentissage – CAM Table

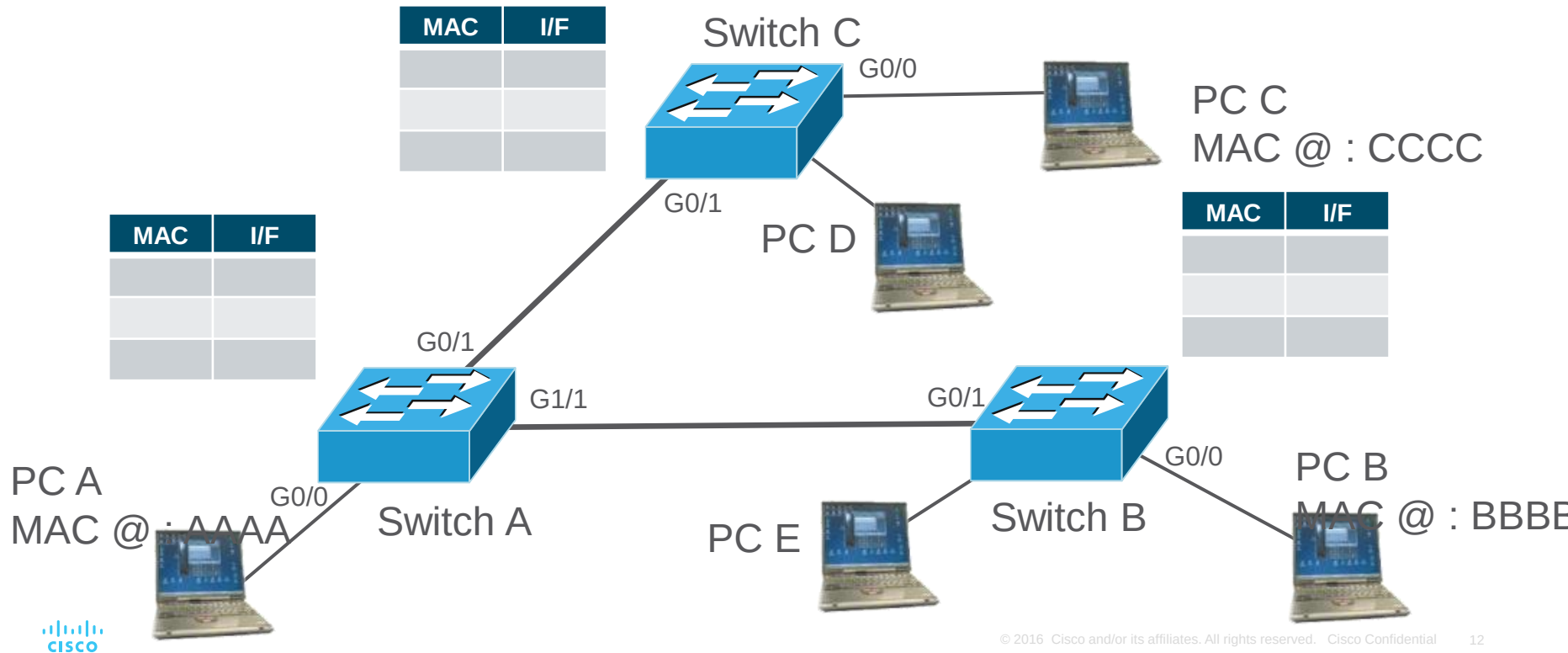


Table d'auto-apprentissage – CAM Table

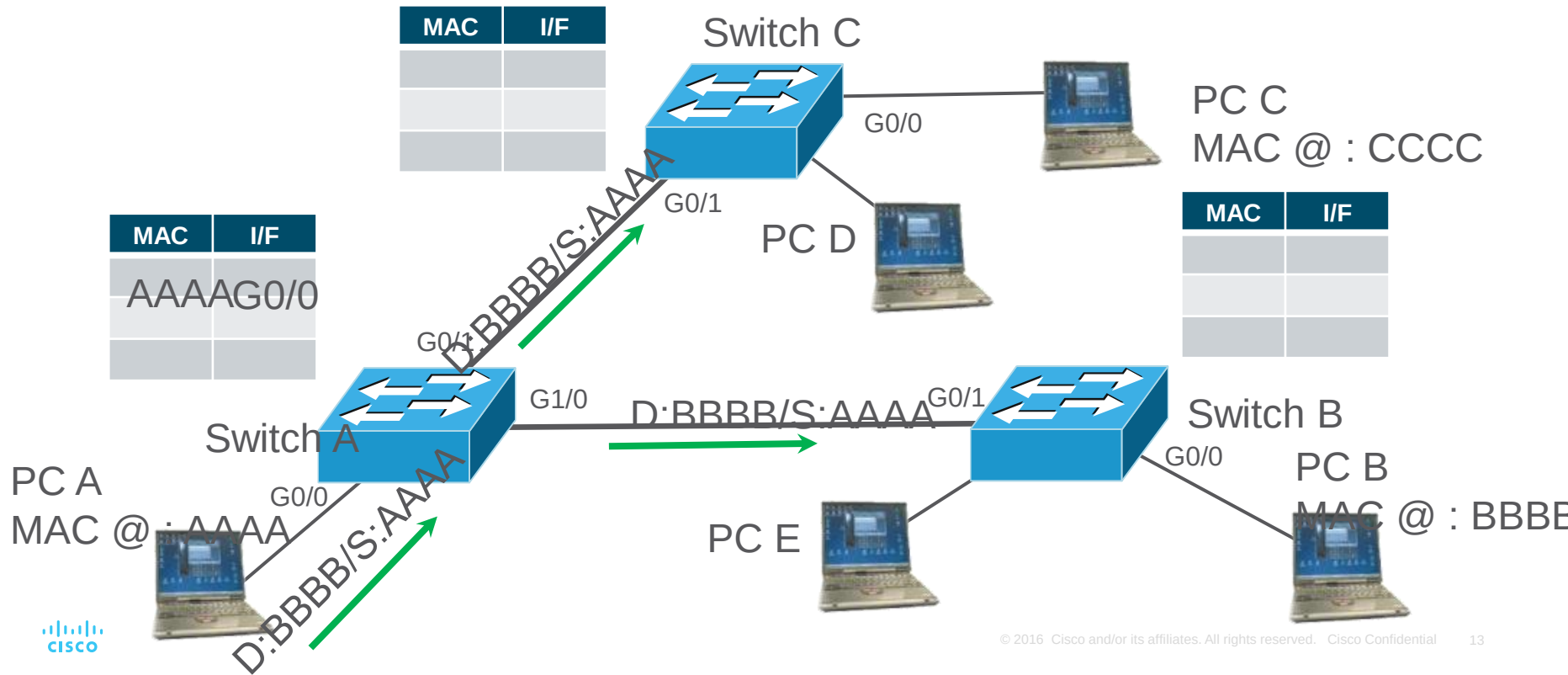


Table d'auto-apprentissage – CAM Table

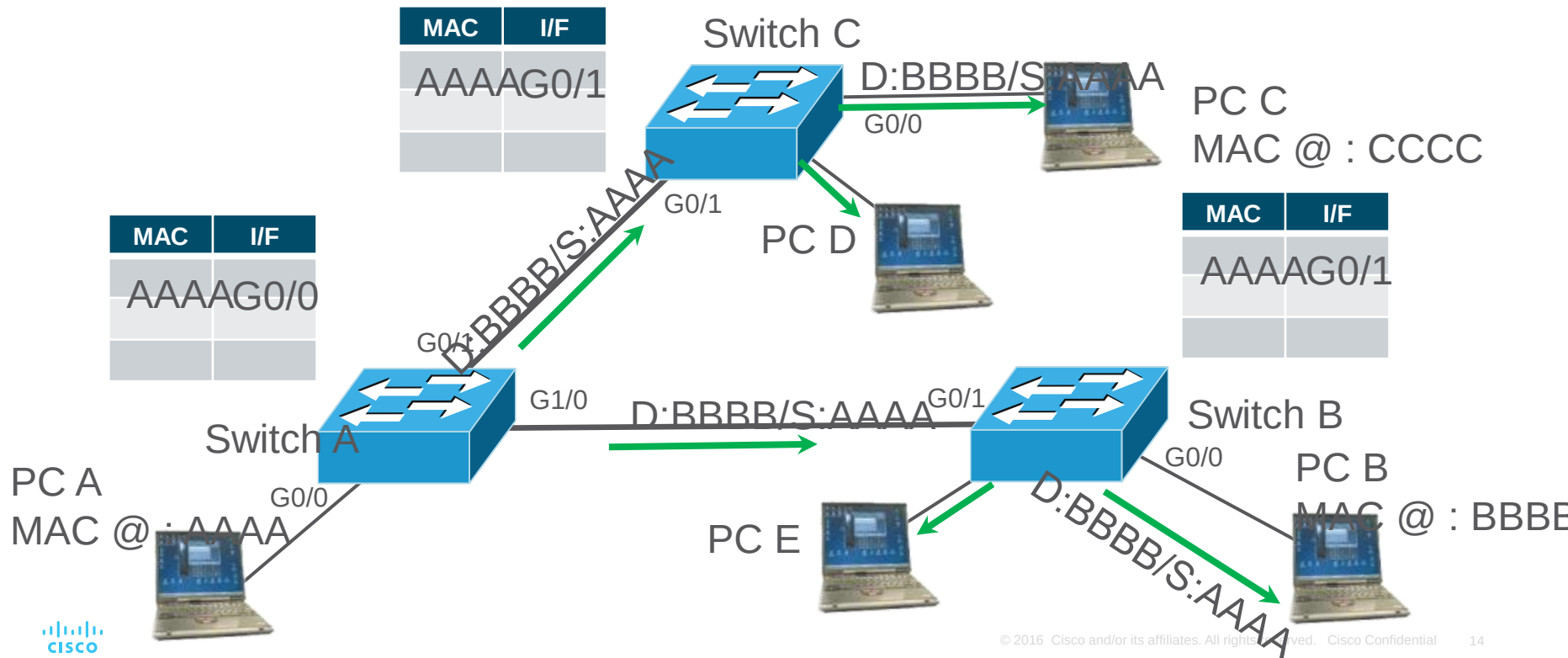


Table d'auto-apprentissage – CAM Table

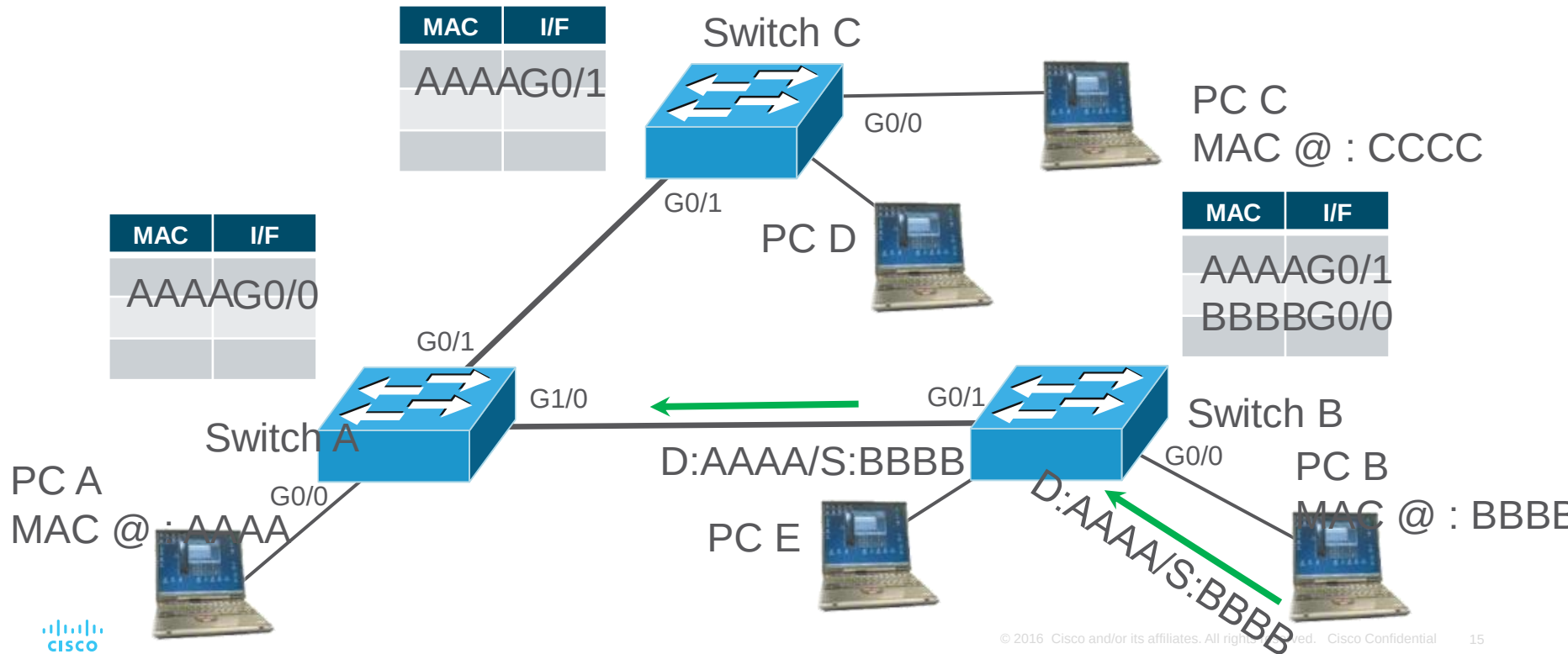
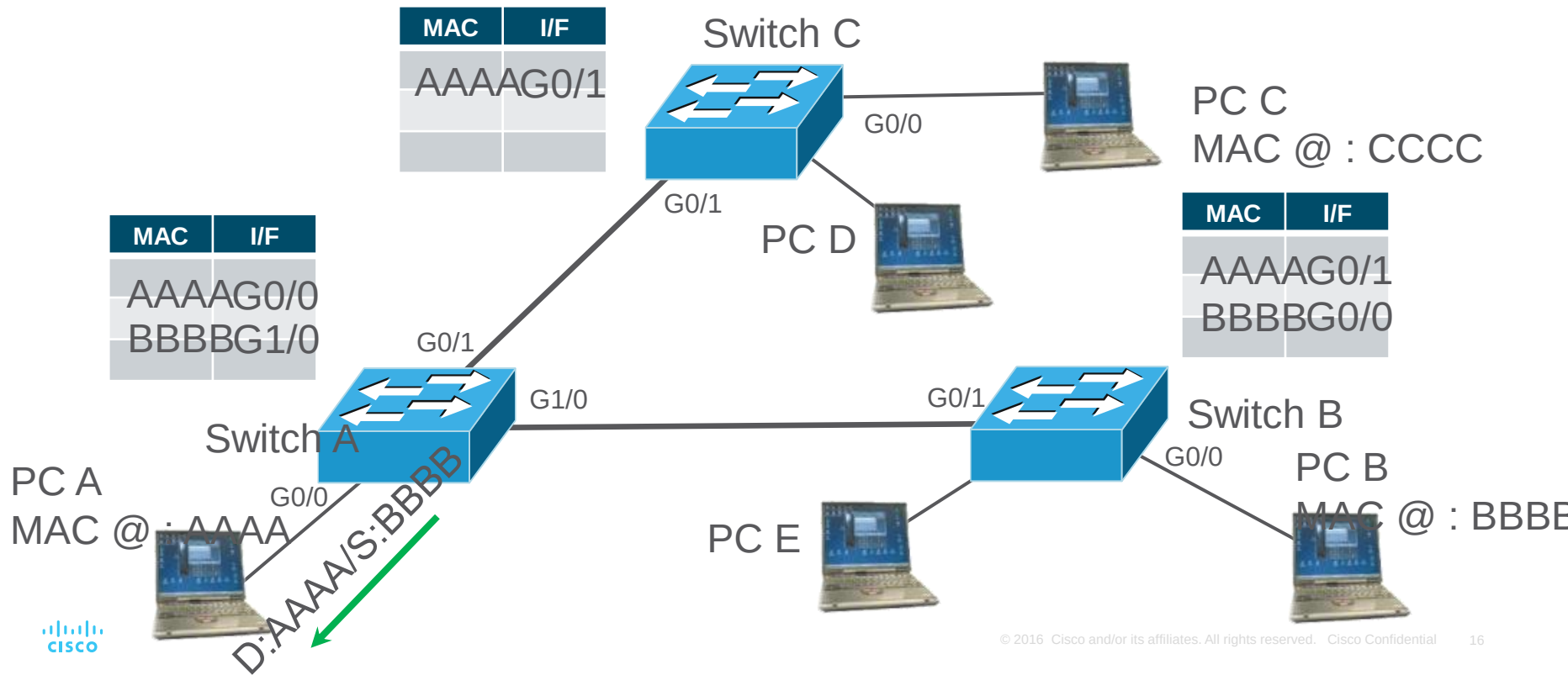
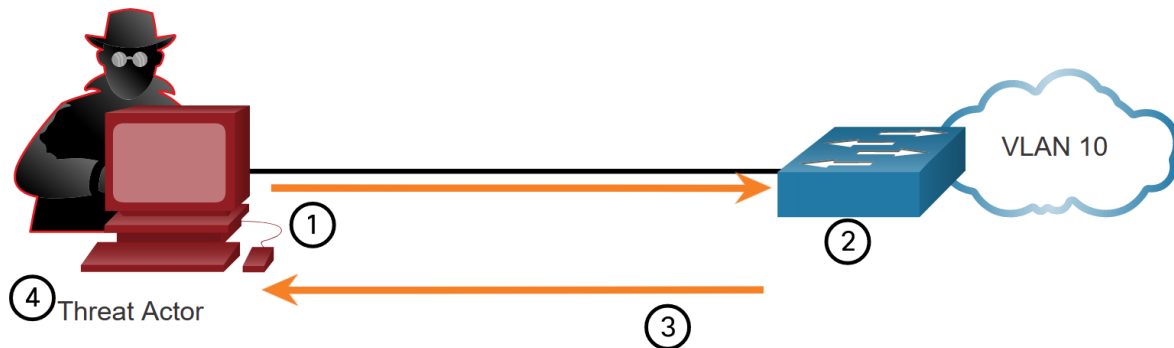


Table d'auto-apprentissage – CAM Table



MAC Address Table Flooding

All MAC tables have a fixed size and consequently, a switch can run out of resources in which to store MAC addresses. MAC address flooding attacks take advantage of this limitation by bombarding the switch with fake source MAC addresses until the switch MAC address table is full.



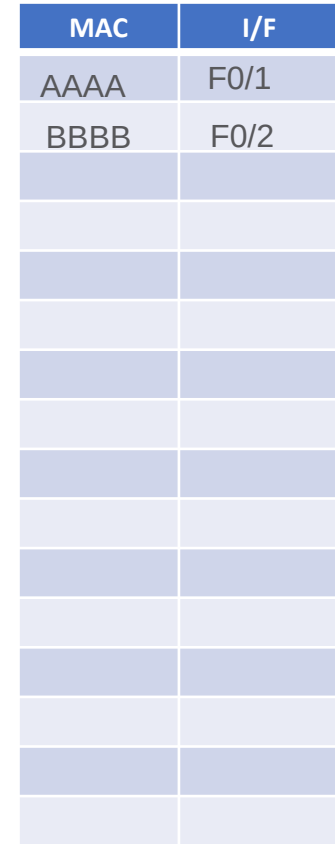
1. The threat actor is connected to VLAN 10 and uses **macof** to rapidly generate many random source and destination MAC and IP addresses.
2. Over a short period of time, the switch's MAC table fills up.
3. When the MAC table is full, the switch begins to flood all frames that it receives. As long as **macof** continues to run, the MAC table remains full and the switch continues to flood all incoming frames out every port associated with VLAN 10.
4. The threat actor then uses packet sniffing software to capture frames from any and all devices connected to VLAN 10.

MAC Address Table Attack Mitigation

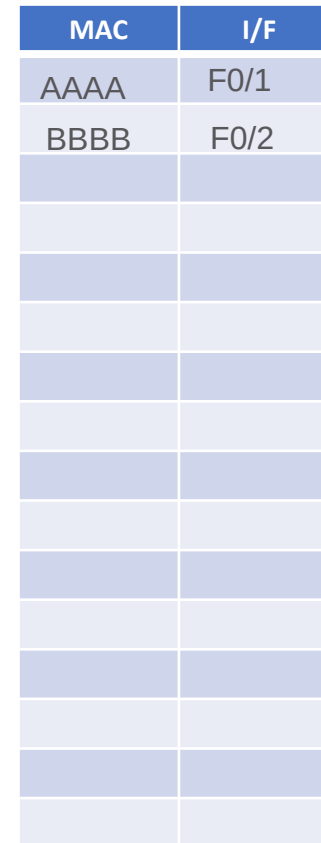
What makes tools such as **macof** so dangerous is that an attacker can create a MAC table overflow attack very quickly. These attack tools are dangerous because they not only affect the local switch, but because they can also affect other connected Layer 2 switches.

To mitigate MAC address table overflow attacks, network administrators must implement port security. Port security will only allow a specified number of source MAC addresses to be learned on the port.

MAC Address Table Flooding

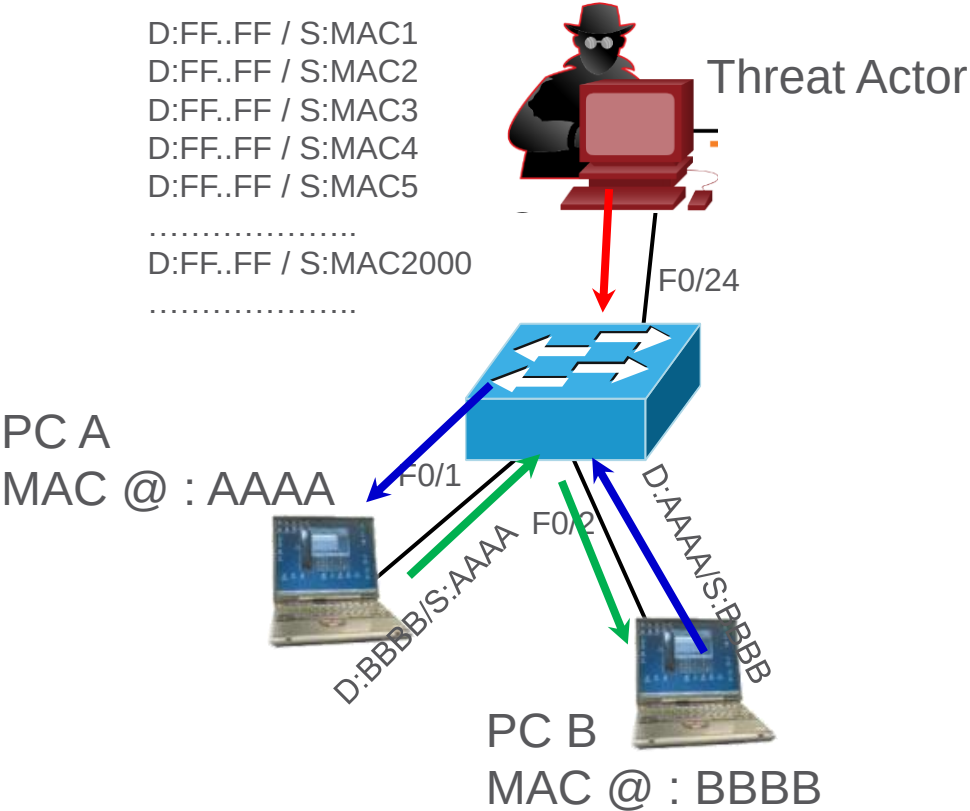


MAC Address Table Flooding



MAC Table Attacks

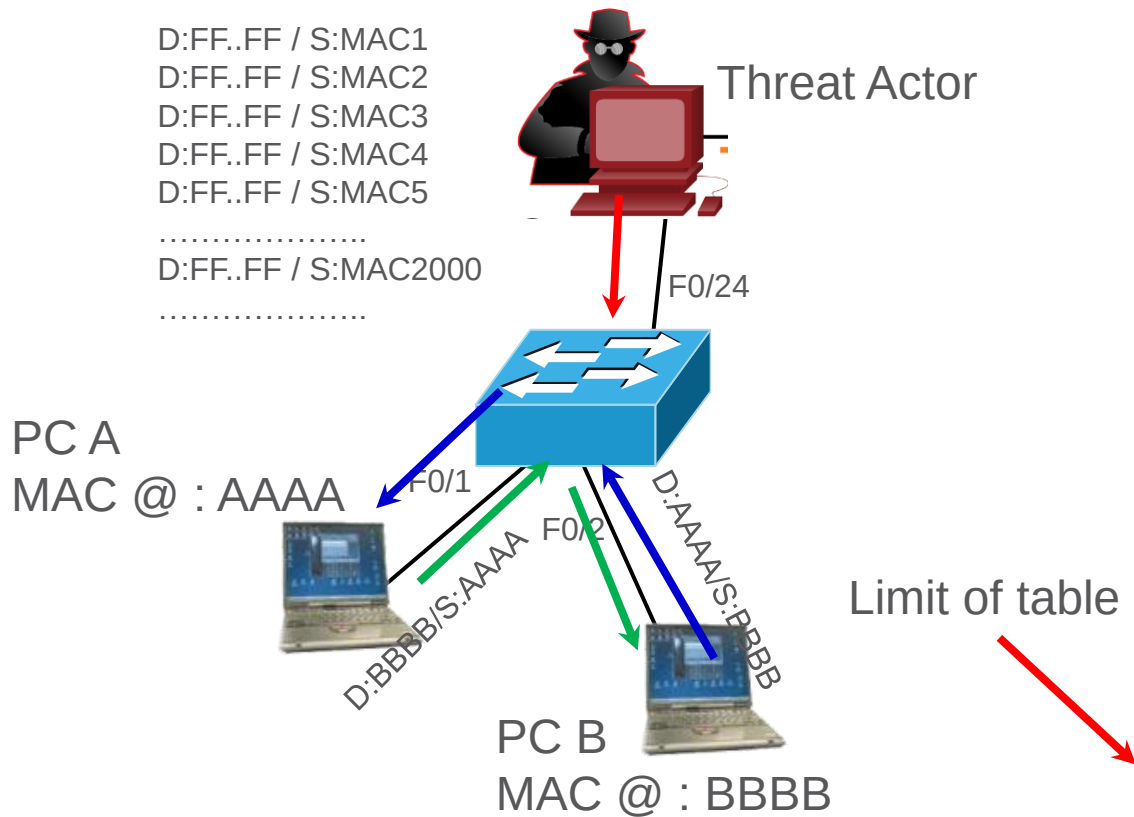
MAC Address Table Flooding



MAC	I/F
AAAA	F0/1
BBBB	F0/2
MAC1	F0/24
MAC2	F0/24
MAC3	F0/24
MAC4	F0/24
MAC5	F0/24
	
	
	
MAC2000	F0/24
	
	
	
	
	

MAC Table Attacks

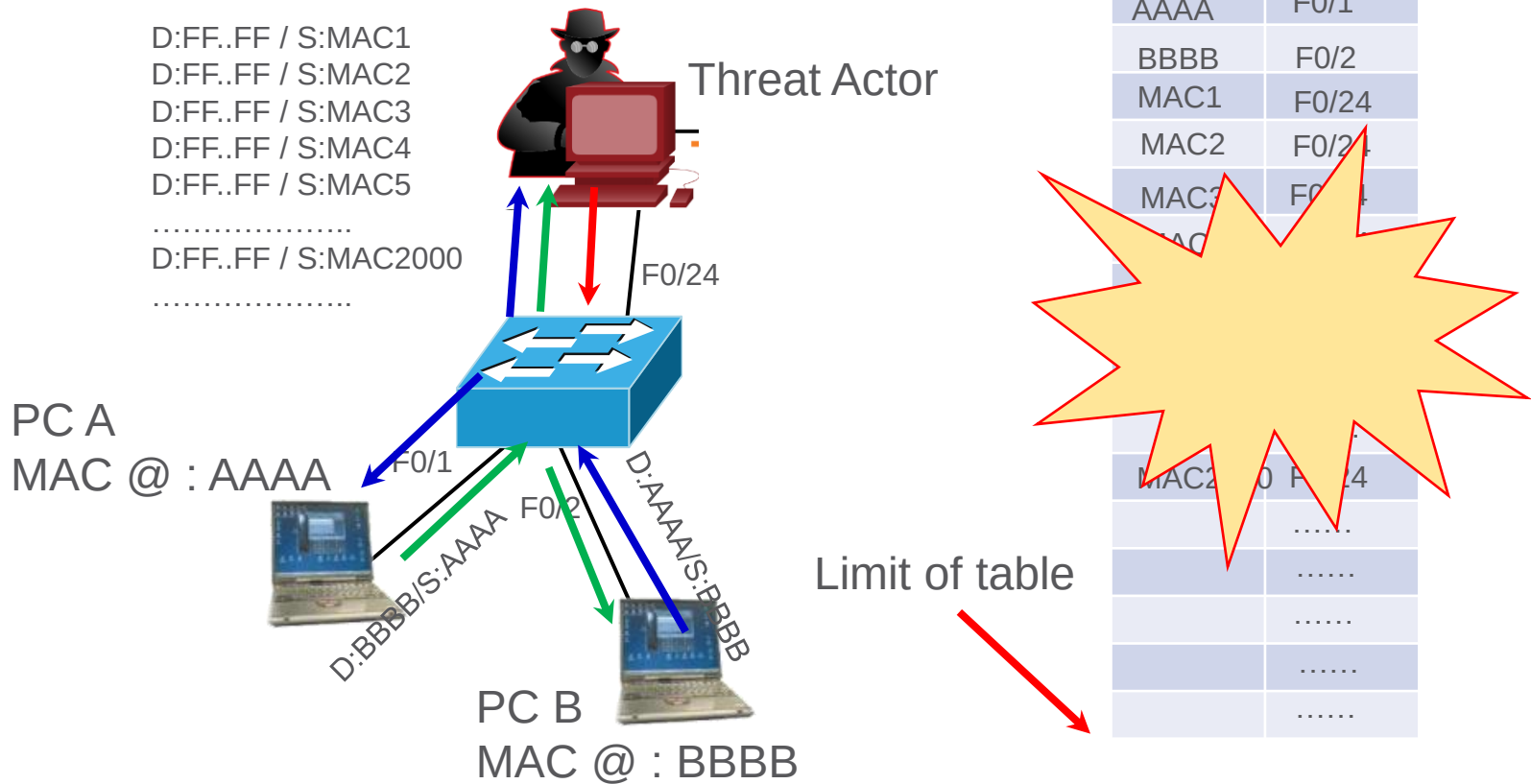
MAC Address Table Flooding



MAC	I/F
AAAA	F0/1
BBBB	F0/2
MAC1	F0/24
MAC2	F0/24
MAC3	F0/24
MAC4	F0/24
MAC5	F0/24
	
	
	
MAC2000	F0/24
	
	
	
	
	

MAC Table Attacks

MAC Address Table Flooding



Mitigate MAC Table Attacks

Secure Unused Ports

All switch ports (interfaces) should be secured before the switch is deployed for production use. How a port is secured depends on its function.

A simple method that many administrators use to help secure the network from unauthorized access is to disable all unused ports on a switch.

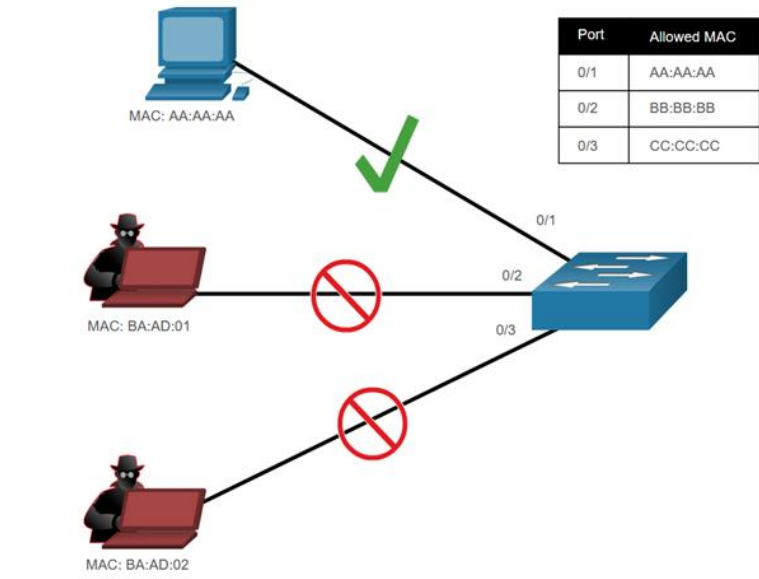
```
S1(config)# interface range fa0/8 - 24
S1(config-if-range)# shutdown
%LINK-5-CHANGED: Interface FastEthernet0/8, changed state to administratively down
(output omitted)
%LINK-5-CHANGED: Interface FastEthernet0/24, changed state to administratively down
S1(config-if-range)#
```

Mitigate MAC Table Attacks

Mitigate MAC Address Table Attacks

Port security limits the number of valid MAC addresses allowed on a port. It allows an administrator to manually configure MAC addresses for a port or to permit the switch to dynamically learn a limited number of MAC addresses. When a port that is configured with port security receives a frame, the source MAC address of the frame is compared to the list of secure source MAC addresses that were manually configured or dynamically learned on the port.

By limiting the number of permitted MAC addresses on a port to one, port security can be used to control unauthorized access to the network, as shown in the figure.



Note: MAC addresses are shown as 24 bits for simplicity.

Mitigate MAC Table Attacks

Enable Port Security

The **switchport port-security** interface configuration command for port security can only be configured on manually configured access ports or manually configured trunk ports. By default, Layer 2 switch ports are set to dynamic auto (trunking on).

Use the **show port-security interface** command to display the current port security settings for FastEthernet 0/1, as shown in the example. Notice that port security is enabled, and the port status is Secure-down, which means there are no devices attached and no violation has occurred. Also, the violation mode is Shutdown, and the maximum number of MAC addresses allowed is 1.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security
Command rejected: FastEthernet0/1 is a dynamic port.
S1(config-if)# switchport mode access
S1(config-if)# switchport port-security
S1(config-if)# end
S1#
```

```
S1# show port-security interface f0/1
Port Security                : Enabled
Port Status                  : Secure-down
Violation Mode                : Shutdown
Aging Time                   : 0 mins
Aging Type                    : Absolute
SecureStatic Address Aging   : Disabled
Maximum MAC Addresses        : 1
Total MAC Addresses          : 0
Configured MAC Addresses     : 0
Sticky MAC Addresses         : 0
Last Source Address:Vlan     : 0000.0000.0000:0
Security Violation Count     : 0
S1#
```

Limit and Learn MAC Addresses

To set the maximum number of MAC addresses allowed on a port, use the **switchport port-security maximum** *value* command.

The switch can be configured to learn about MAC addresses on a secure port in one of three ways:

1. **Manually Configured** - The administrator manually configures a static MAC address(es) by using the **switchport port-security mac-address** *mac-address* command for each secure MAC address on the port.
2. **Dynamically Learned** - When the **switchport port-security** command is entered, the current source MAC for the device connected to the port is automatically secured but is not added to the startup configuration. If the switch is rebooted, the port will have to re-learn the device's MAC address.
3. **Dynamically Learned – Sticky** - The administrator can enable the switch to dynamically learn the MAC address and “stick” them to the running configuration by using the **switchport port-security mac-address sticky** command.

Port Security Aging

Port security aging can be used to set the aging time for static and dynamic secure addresses on a port. Two types of aging are supported per port:

- **Absolute** - The secure addresses on the port are deleted after the specified aging time.
- **Inactivity** - The secure addresses on the port are deleted only if they are inactive for the specified aging time.

Use aging to remove secure MAC addresses on a secure port without manually deleting the existing secure MAC addresses.

Parameter	Description
<code>static</code>	Enable aging for statically configured secure addresses on this port.
<code>time time</code>	Specify the aging time for this port. The range is 0 to 1440 minutes. If the time is 0, aging is disabled for this port.
<code>type absolute</code>	Set the absolute aging time. All the secure addresses on this port age out exactly after the time (in minutes) specified and are removed from the secure address list.
<code>type inactivity</code>	Set the inactivity aging type. The secure addresses on this port age out only if there is no data traffic from the secure source address for the specified time period.

Port Security Violation Modes

If the MAC address of a device that is attached to the port differs from the list of secure addresses, then a port violation occurs. By default, the port enters the error-disabled state. To set the port security violation mode, use the **switchport port-security violation { protect | restrict | shutdown}** command.

The following table shows security violation mode descriptions.

Mode	Description
shutdown (default)	The port transitions to the error-disabled state immediately, turns off the port LED, and sends a syslog message. It increments the violation counter. When a secure port is in the error-disabled state, an administrator must re-enable it by entering the shutdown and no shutdown commands.
restrict	The port drops packets with unknown source addresses until you remove a sufficient number of secure MAC addresses to drop below the maximum value or increase the maximum value. This mode causes the Security Violation counter to increment and generates a syslog message.
protect	This is the least secure of the security violation modes. The port drops packets with unknown MAC source addresses until you remove a sufficient number of secure MAC addresses to drop below the maximum value or increase the maximum value. No syslog message is sent.

Port Security Violation Modes (Cont.)

The following table shows a security violation mode comparison.

Violation Mode	Discards Offending Traffic	Sends Syslog Message	Increase Violation Counter	Shuts Down Port
Protect	Yes	No	No	No
Restrict	Yes	Yes	Yes	No
Shutdown	Yes	Yes	Yes	Yes

The figure on the right, shows an administrator changing the security violation to “restrict”. The output of the **show port-security interface** command confirms that the change has been made.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security violation restrict
S1(config-if)# end
S1#
S1# show port-security interface f0/1
Port Security           : Enabled
Port Status             : Secure-up
Violation Mode          : Restrict
Aging Time              : 10 mins
Aging Type              : Inactivity
SecureStatic Address Aging : Disabled
Maximum MAC Addresses   : 2
Total MAC Addresses     : 2
Configured MAC Addresses : 1
Sticky MAC Addresses    : 1
Last Source Address:Vlan : a41f.7272.676a:1
Security Violation Count : 0
S1#
```

Ports in error-disabled State

What happens when the port security violation is shutdown and a port violation occurs? The port is physically shut down and placed in the error-disabled state, and no traffic is sent or received on that port.

In the example, the port security violation is changed back to the default shutdown setting. Then the host with MAC address a41f.7272.676a is disconnected and a new host is plugged into Fa0/1. Notice that a series of port security related messages are generated on the console.

```
S1(config)# int fa0/1
S1(config-if)# switchport port-security violation shutdown
S1(config-if)# end
S1#
*Mar 1 00:24:15.599: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to down
*Mar 1 00:24:16.606: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
*Mar 1 00:24:19.114: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to up
*Mar 1 00:24:20.121: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to up
S1#
*Mar 1 00:24:32.829: %PM-4-ERR_DISABLE: psecure-violation error detected on Fa0/1, putting
Fa0/1 in err-disable state
*Mar 1 00:24:32.838: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused
by MAC address a41f.7273.018c on port FastEthernet0/1.
*Mar 1 00:24:33.836: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to down
*Mar 1 00:24:34.843: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
S1#
```

Verify Port Security

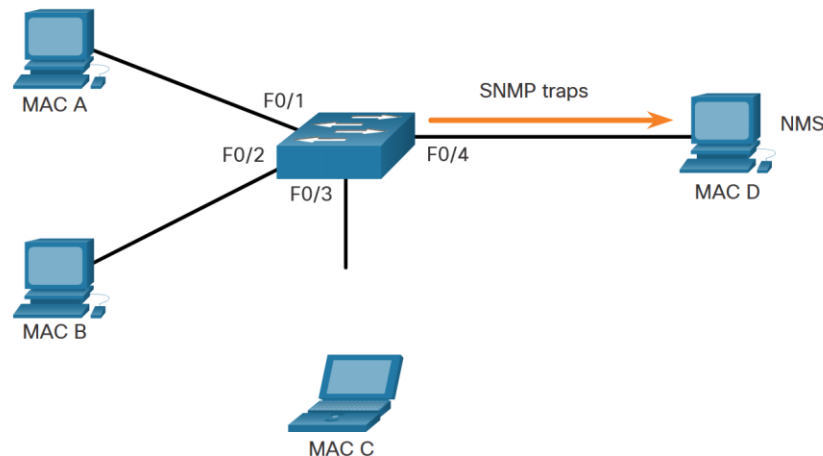
After configuring port security on a switch, check each interface to verify that the port security is set correctly, and check to ensure that the static MAC addresses have been configured correctly.

- To display port security settings for the switch, use the **show port-security** command.
- Use the **show port-security interface** command to view details for a specific interface.
- To verify that MAC addresses are “sticking” to the configuration, use the **show run** command.
- To display all secure MAC addresses that are manually configured or dynamically learned on all switch interfaces, use the **show port-security address** command.

SNMP MAC Address Notification

The MAC address notification feature sends SNMP traps to the network management station (NMS) whenever a new MAC address is added to, or an old address is deleted from, the forwarding tables. MAC address notifications are generated only for dynamic and secure MAC addresses.

Use the **mac address-table notification** global configuration command to enable the MAC address notification feature on a switch.



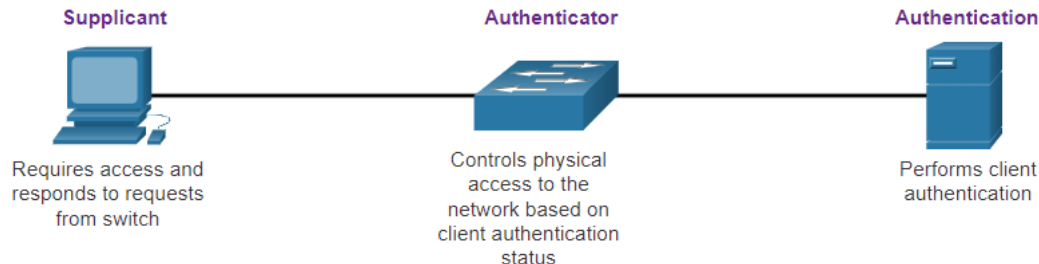
Access Control

802.1X

The IEEE 802.1X standard is a port-based access control and authentication protocol. This protocol restricts unauthorized workstations from connecting to a LAN through publicly accessible switch ports. The authentication server authenticates each workstation that is connected to a switch port before making available any services offered by the switch or the LAN.

With 802.1X port-based authentication, the devices in the network have specific roles:

- **Client (Supplicant)** - This is a device running 802.1X-compliant client software, which is available for wired or wireless devices.
- **Switch (Authenticator)** –The switch acts as an intermediary between the client and the authentication server. It requests identifying information from the client, verifies that information with the authentication server, and relays a response to the client. Another device that could act as authenticator is a wireless access point.
- **Authentication server** –The server validates the identity of the client and notifies the switch or wireless access point that the client is or is not authorized to access the LAN and switch services.



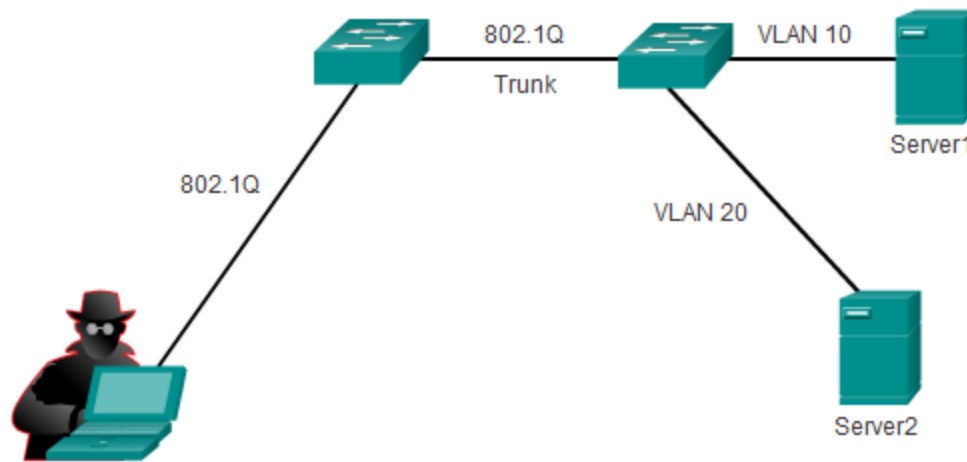
Mitigate VLAN Attacks

VLAN Attacks

- There are a number of different types of VLAN attacks that are prevalent in modern switched networks.
- It is important to understand the general methodology behind these attacks and the primary approaches to mitigate them.
- Common VLAN attacks include:
 - VLAN hopping attack
 - Double-Tagging VLAN attack

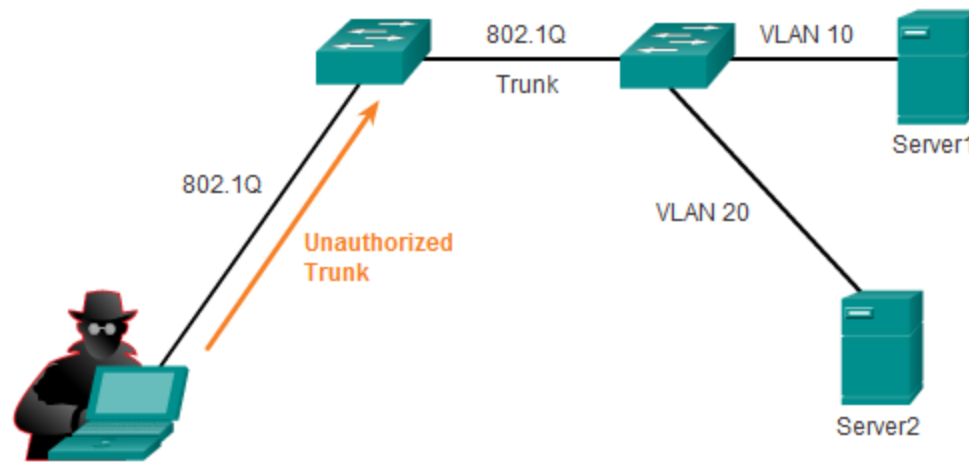
VLAN Hopping Attacks Example

The attacker takes advantage of the default automatic trunking configuration on most switches and configures a system to spoof itself as a switch.



VLAN Hopping Attacks Example

The switch creates a trunk link with the host enabling the attacker to gain access to all the VLANs on the trunk port, and the attacker can now send and receive traffic on all the VLANs.



Attacker gains access to the server VLAN.

VLAN Hopping Attacks Example

- The best way to prevent a basic VLAN hopping attack is to turn off trunking on all ports, except the ones that specifically require trunking.
- On the required trunking ports, disable DTP (auto trunking) negotiations and manually enable trunking and access

Double-Tagging VLAN Attack

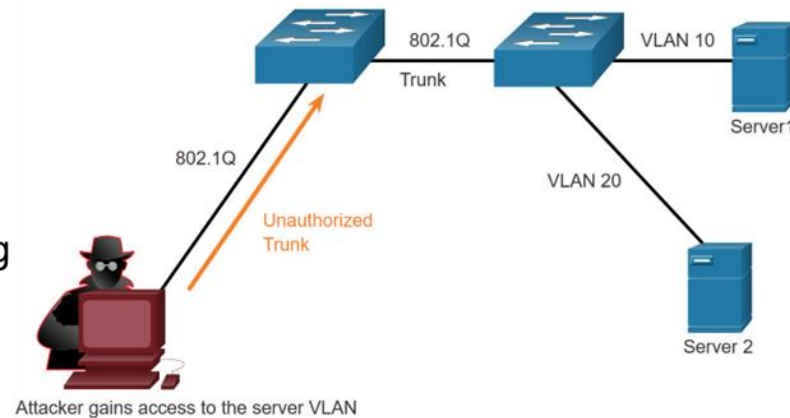
- Also called double-encapsulated VLAN hopping attack
- This attack takes advantage of the way that most perform only one level of 802.1Q decapsulation which allow an attacker in specific situations to embed a hidden 802.1Q tag inside the frame.
- This tag allows the frame to go to a VLAN that the original 802.1Q tag did not specify.

Double-Tagging VLAN Attack

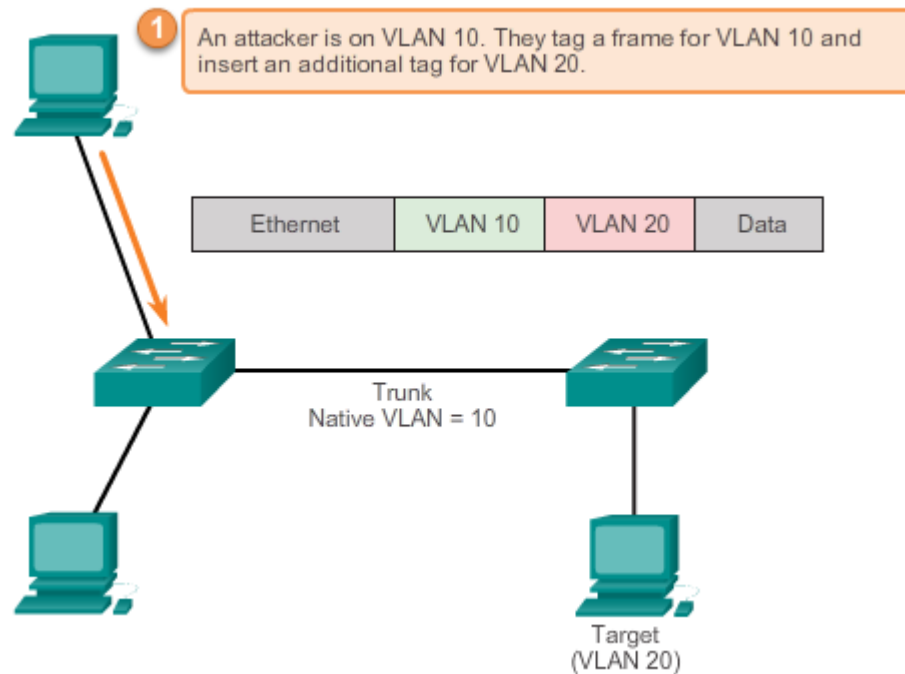
Two types of VLAN attacks are VLAN hopping attacks and VLAN double-tagging attacks.

In a basic VLAN hopping attack, the threat actor configures a host to act like a switch to take advantage of the automatic trunking port feature enabled by default on most switch ports.

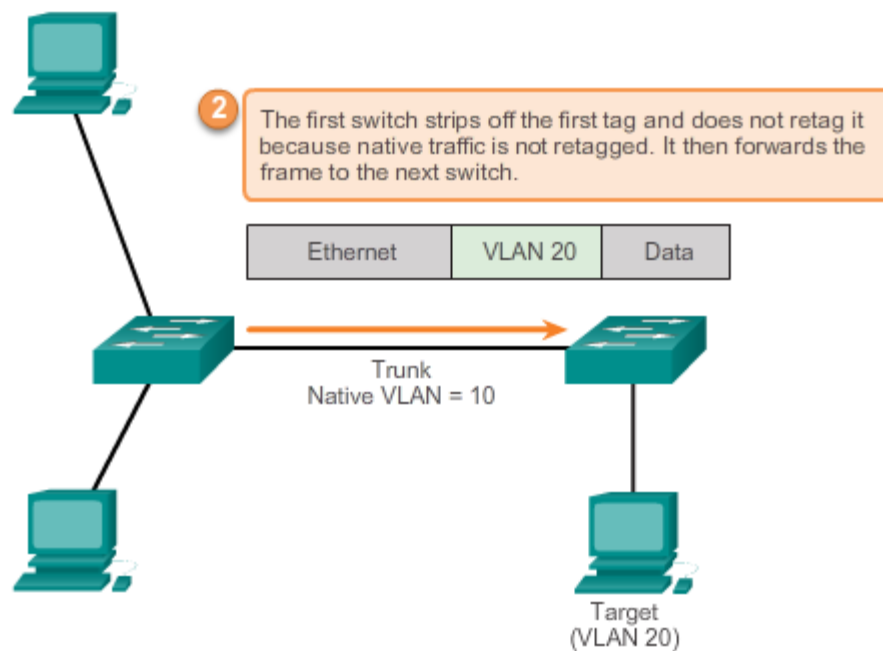
The threat actor configures the host to spoof 802.1Q signaling and Cisco-proprietary Dynamic Trunking Protocol (DTP) signaling to trunk with the connecting switch. If successful, the switch establishes a trunk link with the host, as shown in the figure. Now the threat actor can access all the VLANs on the switch. The threat actor can send and receive traffic on any VLAN, effectively hopping between VLANs.



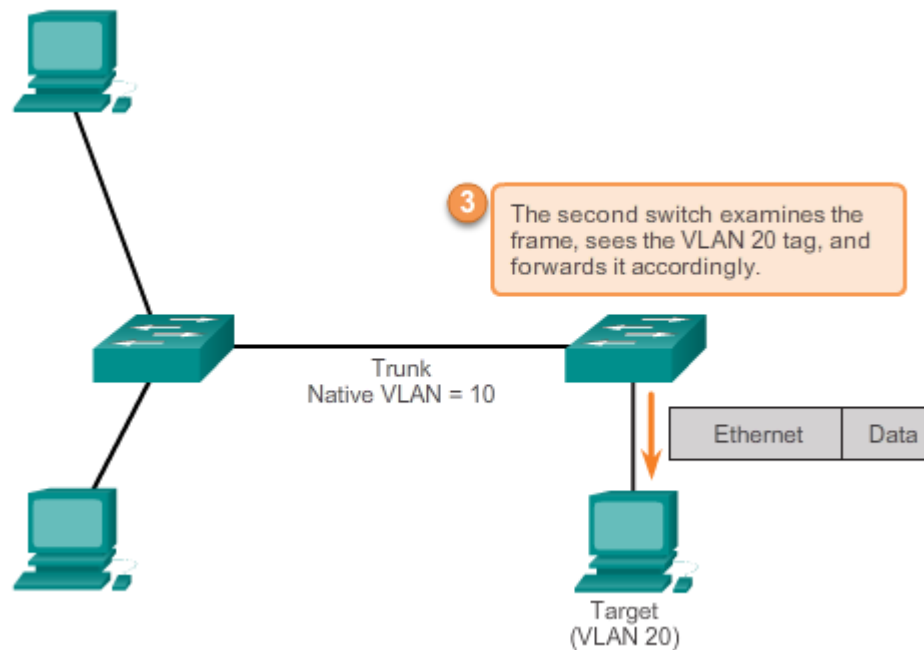
Double-Tagging VLAN Attack (1)



Double-Tagging VLAN Attack (2)



Double-Tagging VLAN Attack (3)



Mitigating VLAN Hopping Attacks

Use the following steps to mitigate VLAN hopping attacks:

Step 1: Disable DTP (auto trunking) negotiations on non-trunking ports by using the **switchport mode access** interface configuration command.

Step 2: Disable unused ports and put them in an unused VLAN. In the example it is VLAN 1000.

Step 3: Manually enable the trunk link on a trunking port by using the **switchport mode trunk** command.

Step 4: Disable DTP (auto trunking) negotiations on trunking ports by using the **switchport nonegotiate** command.

Step 5: Set the native VLAN to a VLAN other than VLAN 1 by using the **switchport trunk native vlan *vlan_number*** command.

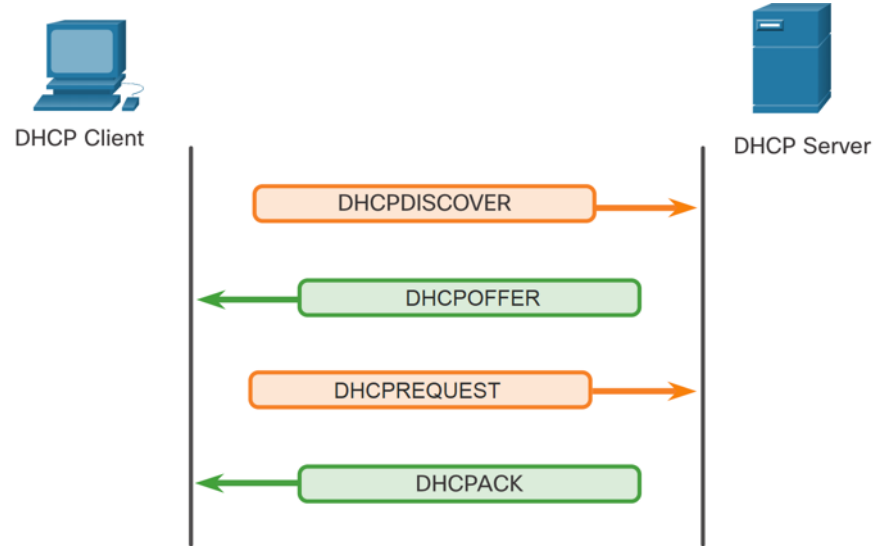
Mitigate DHCP Attacks

Mitigate DHCP Attacks

DHCP Operation

The DHCP Process:

- When an IPv4, DHCP-configured device boots up or connects to the network, the client broadcasts a DHCP discover (DHCPDISCOVER) message to identify any available DHCP servers on the network.
- A DHCP server replies with a DHCP offer (DHCPOFFER) message, which offers a lease to the client. (If a client receives more than one offer due to multiple DHCP servers on the network, it must choose one.)
- The client sends a DHCP request (DHCPREQUEST) message that identifies the explicit server and lease offer that the client is accepting.
- The server then returns a DHCP acknowledgment (DHCPACK) message that acknowledges to the client that the lease has been finalized.
- If the offer is no longer valid, then the selected server responds with a DHCP negative acknowledgment (DHCPNAK) message and the process must begin with a new DHCPDISCOVER message.



Note: DHCPv6 has a set of messages that is similar to those for DHCPv4. The DHCPv6 messages are SOLICIT, ADVERTISE, INFORMATION REQUEST, and REPLY.

DHCP Attacks

Two types of DHCP attacks are DHCP starvation and DHCP spoofing. Both attacks are mitigated by implementing DHCP snooping.

- **DHCP Starvation Attack** - The goal of the DHCP starvation attack is DoS for connecting clients. DHCP starvation attacks require an attack tool such as Gobbler.
- **DHCP Spoofing Attack** - A DHCP spoofing attack occurs when a rogue DHCP server is connected to the network and provides false IP configuration parameters to legitimate clients. A rogue server can provide a variety of misleading information including wrong default gateway, wrong DNS server, and wrong IP address.

DHCP Attacks Mitigation

It is easy to mitigate DHCP starvation attacks by using port security. However, mitigating DHCP spoofing attacks requires more protection.

DHCP spoofing attacks can be mitigated using DHCP snooping on trusted ports. DHCP snooping also helps mitigate against DHCP starvation attacks by rate limiting the number of DHCP discovery messages that an untrusted port can receive. DHCP snooping builds and maintains a DHCP snooping binding database that the switch can use to filter DHCP messages from untrusted sources.

When DHCP snooping is enabled on an interface or VLAN, and a switch receives a packet on an untrusted port, the switch compares the source packet information with the information held in the DHCP snooping binding table. The switch will deny packets containing specific information.

Steps to Implement DHCP Snooping

Use the following steps to enable DHCP snooping:

Step 1. Enable DHCP snooping by using the **ip dhcp snooping** global configuration command.

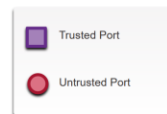
Step 2. On trusted ports, use the **ip dhcp snooping trust** interface configuration command.

Step 3. Limit the number of DHCP discovery messages that can be received per second on untrusted ports by using the **ip dhcp snooping limit rate** interface configuration command.

Step 4. Enable DHCP snooping by VLAN, or by a range of VLANs, by using the **ip dhcp snooping vlan** global configuration command.

DHCP Snooping Configuration Example

The reference topology for this DHCP snooping example is shown in the figure. Notice that F0/5 is an untrusted port because it connects to a PC. F0/1 is a trusted port because it connects to the DHCP server.



The following is an example of how to configure DHCP snooping on S1. Notice how DHCP snooping is first enabled.

```
S1(config)# ip dhcp snooping
S1(config)# interface f0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# interface range f0/5 - 24
S1(config-if-range)# ip dhcp snooping limit rate 6
S1(config-if-range)# exit
S1(config)# ip dhcp snooping vlan 5,10,50-52
S1(config)# end
S1#
```

Use the **show ip dhcp snooping** privileged EXEC command to verify DHCP snooping and **show ip dhcp snooping binding** to view the clients that have received DHCP information.

Mitigate ARP Attacks

ARP Attacks

In a typical attack, a threat actor can send unsolicited ARP Replies to other hosts on the subnet with the MAC Address of the threat actor and the IPv4 address of the default gateway.

There are many tools available on the internet to create ARP man-in-the-middle attacks including dsniff, Cain & Abel, ettercap, Yersinia, and others. IPv6 uses ICMPv6 Neighbor Discovery Protocol for Layer 2 address resolution. IPv6 includes strategies to mitigate Neighbor Advertisement spoofing, similar to the way IPv6 prevents a spoofed ARP Reply.

ARP spoofing and ARP poisoning are mitigated by implementing Dynamic ARP Inspection (DAI).

Dynamic ARP Inspection

In a typical ARP attack, a threat actor can send unsolicited ARP requests to other hosts on the subnet with the MAC Address of the threat actor and the IP address of the default gateway.

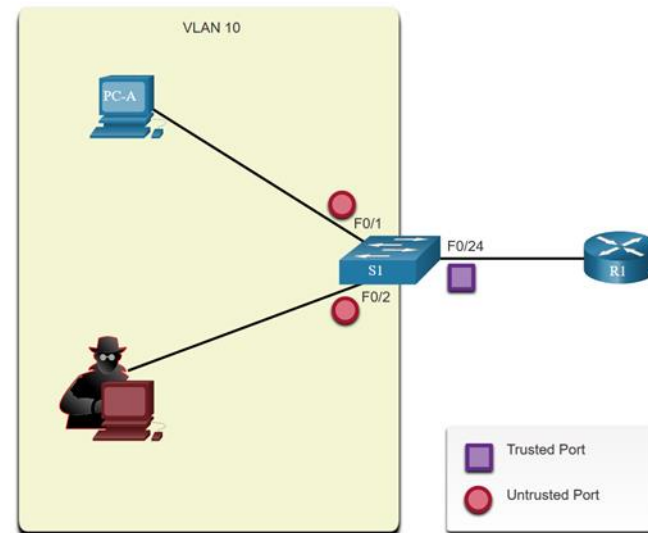
Dynamic ARP inspection (DAI) requires DHCP snooping and helps prevent ARP attacks by:

- Not relaying invalid or gratuitous ARP Requests out to other ports in the same VLAN.
- Intercepting all ARP Requests and Replies on untrusted ports.
- Verifying each intercepted packet for a valid IP-to-MAC binding.
- Dropping and logging ARP Requests coming from invalid sources to prevent ARP poisoning.
- Error-disabling the interface if the configured DAI number of ARP packets is exceeded.

DAI Implementation Guidelines

To mitigate the chances of ARP spoofing and ARP poisoning, follow these DAI implementation guidelines:

- Enable DHCP snooping globally.
- Enable DHCP snooping on selected VLANs.
- Enable DAI on selected VLANs.
- Configure trusted interfaces for DHCP snooping and ARP inspection.



DAI Configuration Example

In the previous topology, S1 is connecting two users on VLAN 10. DAI will be configured to mitigate against ARP spoofing and ARP poisoning attacks.

As shown in the example, DHCP snooping is enabled because DAI requires the DHCP snooping binding table to operate. Next, DHCP snooping and ARP inspection are enabled for the PCs on VLAN10. The uplink port to the router is trusted, and therefore, is configured as trusted for DHCP snooping and ARP inspection.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10
S1(config)# ip arp inspection vlan 10
S1(config)# interface fa0/24
S1(config-if)# ip dhcp snooping trust
S1(config-if)# ip arp inspection trust
```

DAI Configuration Example (Cont.)

DAI can also be configured to check for both destination or source MAC and IP addresses:

- **Destination MAC** - Checks the destination MAC address in the Ethernet header against the target MAC address in the ARP packet body.
- **Source MAC** - Checks the source MAC address in the Ethernet header against the sender MAC address in the ARP packet body.
- **IP address** - Checks the ARP packet body for invalid and unexpected IP addresses including addresses 0.0.0.0, 255.255.255.255, and all IP multicast addresses.

DAI Configuration Example (Cont.)

The **ip arp inspection validate {src-mac [dst-mac] [ip]}** global configuration command is used to configure DAI to drop ARP packets when the IP addresses are invalid.

```
S1(config)# ip arp inspection validate ?
dst-mac  Validate destination MAC address
ip       Validate IP addresses
src-mac  Validate source MAC address
S1(config)# ip arp inspection validate src-mac
S1(config)# ip arp inspection validate dst-mac
S1(config)# ip arp inspection validate ip
S1(config)# do show run | include validate
ip arp inspection validate ip
S1(config)# ip arp inspection validate src-mac dst-mac ip
S1(config)# do show run | include validate
ip arp inspection validate src-mac dst-mac ip
S1(config)#
```

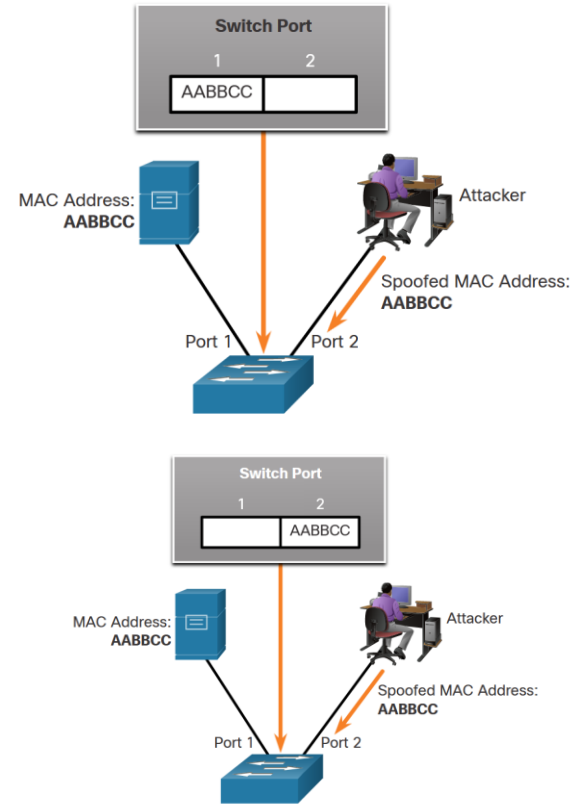
Mitigate Address Spoofing Attacks

Mitigate Address Spoofing Attacks

Address Spoofing Attacks

MAC address spoofing attacks occur when attackers alter the MAC address of their host to match another known MAC address of a target host, as shown in the first figure.

When the switch receives the frame, it examines the source MAC address. The switch overwrites the current MAC table entry and assigns the MAC address to the new port, as shown in the second figure. It then inadvertently forwards frames destined for the target host to the attacking host.



Address Spoofing Attack Mitigation

To protect against MAC and IP address spoofing, configure the IP Source Guard (IPSG) security feature. IPSG operates just like DAI, but it looks at every packet, not just the ARP packets. Like DAI, IPSG also requires that DHCP snooping be enabled.

For each untrusted port, there are two possible levels of IP traffic security filtering:

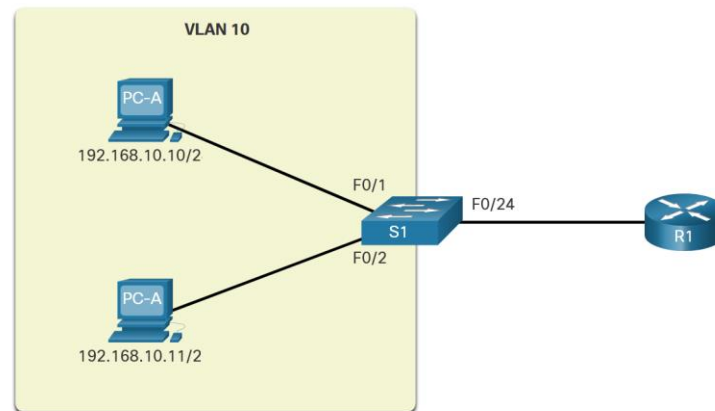
- **Source IP address filter** - IP traffic is filtered based on its source IP address and only IP traffic with a source IP address that matches the IP source binding entry is permitted. When a new IP source entry binding is created or deleted on the port, the per-port VLAN ACL (PVACL) automatically adjusts itself to reflect the IP source binding change.
- **Source IP and MAC address filter** - IP traffic is filtered based on its source IP address in addition to its MAC address. Only IP traffic with source IP and MAC addresses that match the IP source binding entry are permitted.

Configure IP Source Guard

The IP Source Guard reference topology is shown in the figure on the right.

IP Source Guard is enabled on untrusted ports using the **ip verify source** command as shown in the configuration below.

Use the **show ip verify source** command to verify the IP Source Guard configuration.



```
S1(config)# interface range fastethernet 0/1 - 2
S1(config-if-range)# ip verify source
S1(config-if-range)# end
S1#
```

```
S1# show ip verify source
```

Interface	Filter-type	Filter-mode	IP-address	Mac-address	Vlan
F0/1	ip	active	192.168.10.10		10
F0/2	ip	active	192.168.10.11		10

S1#

